

TLP:CLEAR

Анализ угроз на основе ханипотов

Ежемесячный отчёт — май 2026

LLM Abuse | SSRF / Cloud Credentials | Solana Targeting | Mirai/Gafgyt | ICS/IEC-104

Параметр	Значение
Период отчёта	1-31 мая 2026 (2026-05-01 — 2026-06-01 UTC)
Дата анализа	9 июня 2026
Классификация	TLP:CLEAR
Уровень угрозы	СРЕДНИЙ-ВЫСОКИЙ
Узлы ханипотов	DE, US, RU + ICS-приманка подстанции (IEC-104), PL phishing-sink
Объём событий	~911 000 событий атак по всем сервисам
SSH-события	433 871 сессия, 290 621 неудачный логин, 85 payload-загрузок
Образцы малвари	126 уникальных SHA-256 (все вредоносные)

1. Краткое заключение

За май 2026 распределённые сенсоры-приманки (развёрнуты в Германии, США и России) зафиксировали порядка 911 000 событий атак по векторам SSH, многопротокольной эксплуатации, Docker, LLM, MikroTik и Kubernetes. Главное событие месяца — продолжающееся созревание атак на self-hosted LLM-эндпоинты инференса (Ollama, llama.cpp): это самостоятельная категория со своей таксономией, инструментарием и постоянными операторами, которая в мае вышла за рамки кражи compute — к SSRF-краже облачных учётных данных.

Прочая заметная активность: целевая охота на Solana-валидаторы через SSH, мульти-архитектурные дропперы Mirai/Gafgyt, доминирование потока WannaCry/SMB в пойманной малвари и первые ICS-взаимодействия (команды РПН по IEC-104) с новой приманкой подстанции.

2. Сводка по объёмам

SSH (Cowrie), точные счётчики:

Метрика	DE	US	RU	Всего
Сессии	155 620	48 240	228 858	433 871
Успешные логины	3 876	525	4 280	8 753
Неудачные логины	121 842	11 837	156 415	290 621
Команды в shell	1 413	184	1 483	3 080
Скачанные payload-ы	84	1	0	85

Агрегаты по флоту: Dionaea (SMB/MSSQL/MySQL/FTP/SIP) ~734 000 событий; Docker API 4 296; Ollama (LLM) ~75 300 HTTP-запросов; Winbox (MikroTik) 5 700; Kubelet 2 006. Россия лидирует по SSH-объёму, но имеет самый низкий success rate (2.7%) — значительная часть RU-трафика это слепой перебор, чьи словари плохо подходят к учёткам приманки — и ноль payload-загрузок: атакующие ведут разведку (uname), но не доводят до доставки.

3. Находка 1 — Атаки на LLM-эндпоинты инференса (заглавная)

Фейковый Ollama API принял ~75 300 запросов за май. Распределение размеченной части по активности: ~95% сканирование, ~3.7% кража инференса (бесплатный GPU/compute через /api/generate, /v1/chat/completions), ~0.8% abuse внешних моделей и — новое в этом месяце — ~0.5% ssrf_cloud_cred: использование LLM-эндпоинта как SSRF-платформа к cloud-metadata (169.254.169.254) для кражи IAM-кредов. Это качественный сдвиг от кражи compute к компрометации самой инфраструктуры.

Цель — не только Ollama: эндпоинт /props (1 282 запроса) специфичен для серверов llama.cpp, а соседнее зондирование n8n (/rest/oauth2-credential/callback, /api/v1/webhook/test) указывает на охоту за credenшелами AI-оркестрации. Основной инструмент сканирования — официальный Go-клиент Ollama (UA «ollama/0.0.0 (amd64 linux) Go/go1.26.3», 50 529 запросов) и коммерческий сканер AI-активов EchelonGraph-ShadowAIRadar.

Лонгитюд выявляет постоянного оператора: 203[.]159[.]90[.]152 (AS210558 1337 Services GmbH, сеть, которую открытые источники связывают с экосистемой Stark Industries) доминировал на этом векторе в марте-апреле и остался активен в мае (~25% всех запросов к приманке). Лидер мая 37[.]19[.]210[.]21 (AS212238 Datacamp/CDN77, ~67% запросов) — вероятно, VPN-выход, прикрывающий реального оператора. Примечание: AS212238 — крупный shared-хостинг, в отчёте встречается у нескольких несвязанных арендаторов.

4. Находка 2 — Таргетинг Solana-валидаторов (продолжается)

В SSH-словарях устойчиво присутствуют Solana-специфичные креды: username sol (3 378), solana (2 837), solv (1 843); password solana (1 071), sol (1 034). Ботнет целенаправленно ищет Solana-валидаторы/ноды с открытым SSH — кража ключей валидатора или перенаправление стейкинг-наград.

5. Находка 3 — Мульти-архитектурные дропперы Mirai/Gafgyt

85 загрузок, 33 уникальных SHA-256, классическая мульти-arch доставка. Четыре основных dropper-сервера:

Dropper	ASN / geo	Серия payload
103[.]77[.]246[.]174	AS140810 Megacore, VN	полный набор arch + /wget.sh
45[.]81[.]234[.]64	AS44486 synlinc.de, DE	/10Gbins.sh
202[.]71[.]14[.]246	AS43641 Sollutium EU, NL	proto.*
209[.]92[.]170[.]225	AS212238 Datacamp, MY	lmkjn.*

Команда-fingerprint выбора архитектуры «/bin/.uname -s -v -n -r -m» (578 раз) предшествует выбору payload.

6. Находка 4 — Пойманная малварь: доминирование WannaCry/SMB

126 уникальных образцов, все вредоносные (источники: Dionaee 86, Cowrie 36, harvested-dropper 4). Около 85 из 126 — PE32 DLL, детект YARA WannaCry_Ransomware + SUSP_Imphash_Mar23_2 — остаточный WannaCry/EternalBlue SMB-трафик, до сих пор сканирующий интернет. ELF-образцы (35) соответствуют Mirai/Gafgyt-загрузкам выше; SSH-черви — Go_SSHWorm_Generic (5), Panchan_SSHWorm_Go (4), Discord_C2_ELF (5). Примечание: ClamAV дал ноль детектов по всем 126 образцам — текущий поток ловится только YARA/imphash.

7. Находка 5 — ICS-приманка подстанции (IEC-104), предварительно

Недавно развёрнутая ICS-приманка (эмуляция шлюза/RTU подстанции, IEC-104) за неполный период наблюдения зафиксировала 205 событий IEC-104, включая 84 подключения, 62 операции РПН (регулятор напряжения трансформатора) и 28 общих опросов — то есть атакующие подавали команды переключения по эмулируемой SCADA-логике, а не просто подключались. Цифры предварительные ввиду короткого окна наблюдения.

8. Операторы-источники и география

5 542 operator hits (пассивная атрибуция по ASN, не матч по IOC-фиду). Ведущие операторы-источники: DigitalOcean (3 317), OVH (1 127), Alibaba Cloud (409), Amazon AWS (264), VPSVAULT.HOST (157), M247 (130). Ведущие страны: US (11 132), CN (6 648), RO (3 714), NL (3 483), DE (2 845), RU (2 382). Основной объём — с мейнстрим-облаков (арендованные VPS под ботнеты); санкционные/bulletproof-сети (Aeza, бренды Stark) дают малый объём, но именно таргетированную LLM-нагрузку.

9. Ботнет-кампании

SSH-кластеризация выявила кампании до 670 уникальных IP в одном кластере, охват до ~1 900 IP в до 53 параллельных кампаниях. Активные C2: 14[.]46[.]136[.]77 (KR), 151[.]242[.]125[.]187 (HK), 87[.]121[.]79[.]73 (BG).

10. PL phishing-sink

Сенсор-перехватчик фишинга зафиксировал ~387 000 визитов за май. Среди кластеров фишинг-хостов — бренд-имперсонация вендоров электронной подписи и security-awareness, крупные кластеры поддоменов; источники визитов — преимущественно облачные боты.

11. MITRE ATT&CK

- T1595.002 — Active Scanning: Vulnerability Scanning
- T1110 — Brute Force
- T1046 — Network Service Discovery
- T1190 — Exploit Public-Facing Application
- T1610 — Deploy Container
- T1496 — Resource Hijacking (кража инференса/compute)
- T1552.005 — Cloud Instance Metadata API
- T1078.004 — Valid Accounts: Cloud
- T0855 — Unauthorized Command Message (ICS/IEC-104)
- T0836 — Modify Parameter (операция РПН/переключение отпайки, ICS)

12. Индикаторы компрометации (IOC)

Машиночитаемые дампы — iocs.stix2.json (STIX 2.1) и iocs.misp.json (MISP) в каталоге отчёта. В человекочитаемых документах индикаторы defanged, в JSON-дампах — refanged.

TLP:CLEAR — Этот документ может распространяться без ограничений.